

Презентация по лабораторной работе №2

Еюбоглу Тимур, Зиязетдинов Алмаз, Исаев Булат

18 декабря 2025 г.

Российский университет дружбы народов, Москва, Россия

- Еюбоглу Тимур
- 1032224357
- уч. группа: НПИбд-01-22
- Факультет физико-математических и естественных наук
- Российский университет дружбы народов

Внешний злоумышленник проводит многоэтапную атаку на корпоративную инфраструктуру, начиная с эксплуатации уязвимостей на публичных сервисах. Цель атаки — получение контроля над внутренними ресурсами, захват контроллера домена, хищение данных и дестабилизация работы компании.

Выполнение лабораторной работы

← → ↺

Не защищено

https://10.140.2.150/#events

ViPNet IDS NS

mon20

🌐

🔍

☰

Мониторинг

Инфопанель

События

Отчеты

Управление

Сетевое окружение

Методы анализа

Правила анализа

Оповещение

Интеграция

Система

Сетевые настройки

Дата и время

Учетные записи

Резервное копирование

Сервисные функции

Аудит

Журнал аудита

События

События за последние 24 часа

🔍

🔄

№	Дата и время	Код событ...	К...	Название правила	Класс	Г	IP-адрес исто...	Порт ис...	IP-адрес полу...	Порт п...
•	19:24:17.480 12...	3121915	1	ET POLICY Executable and linking format (ELF) file ...	policy-violat...	T	195.239.174.11	5559	10.10.2.22	54634
•	19:24:17.480 12...	3121915	1	ET POLICY Executable and linking format (ELF) file ...	policy-violat...	T	195.239.174.11	5559	10.10.1.253	30238
•	19:24:07.358 12...	3129327	1	ET POLICY Executable and linking format (ELF) file ...	policy-violat...	T	195.239.174.11	8010	10.10.2.22	32798
•	19:24:07.358 12...	3129327	1	ET POLICY Executable and linking format (ELF) file ...	policy-violat...	T	195.239.174.11	8010	10.10.1.253	3648
•	19:22:11.249 12...	2025644	1	ET TROJAN Possible Metasploit Payload Common ...	trojan-activity	T	195.239.174.11	5558	10.10.2.11	20780
•	19:22:11.248 12...	2025644	1	ET TROJAN Possible Metasploit Payload Common ...	trojan-activity	T	195.239.174.11	5558	10.10.1.253	19733
•	19:22:11.087 12...	2025644	1	ET TROJAN Possible Metasploit Payload Common ...	trojan-activity	T	195.239.174.11	5558	10.10.2.11	20781
•	19:22:11.085 12...	2025644	1	ET TROJAN Possible Metasploit Payload Common ...	trojan-activity	T	195.239.174.11	5558	10.10.1.253	1498
•	19:20:20.912 12...	3121915	1	ET POLICY Executable and linking format (ELF) file ...	policy-violat...	T	195.239.174.11	5556	10.10.1.22	59084
•	19:19:53.305 12...	3101541	1	AM EXPLOIT Generic Possible PHP injection: PHP T...	web-applica...	T	195.239.174.11	37861	10.10.1.22	80
•	19:19:53.305 12...	3105228	1	AM EXPLOIT Generic Command Injection in HTTP B...	web-applica...	T	195.239.174.11	37861	10.10.1.22	80
•	19:19:53.305 12...	303254	1	AM EXPLOIT Generic Command Injection in HTTP B...	web-applica...	T	195.239.174.11	37861	10.10.1.22	80
•	19:19:53.305 12...	2011768	1	ET WEB_SERVER PHP tags in HTTP POST	web-applica...	T	195.239.174.11	37861	10.10.1.22	80
•	19:19:53.305 12...	3153066	1	AM EXPLOIT WordPress wpDiscuz 7.0.4 RCE and S...	web-applica...	T	195.239.174.11	37861	10.10.1.22	80
•	19:22:11.240 12...	2035480	1	ET INFO PE EXE Download over raw TCP	misc-activity	T	195.239.174.11	5558	10.10.2.11	20780
•	19:22:11.240 12...	2035480	1	ET INFO PE EXE Download over raw TCP	misc-activity	T	195.239.174.11	5558	10.10.1.253	19733
•	19:22:11.077 12...	2035480	1	ET INFO PE EXE Download over raw TCP	misc-activity	T	195.239.174.11	5558	10.10.2.11	20781
•	19:22:11.077 12...	2035480	1	ET INFO PE EXE Download over raw TCP	misc-activity	T	195.239.174.11	5558	10.10.1.253	1498

Событие 19:19:53.305 12.12.2025

📄

✕

Событие

Источник

Получатель

Пакет

Протокол

TCP

Код события

3153066

Клиентское приложение

Mozilla/5.0 (Macintosh; Intel Mac OS X 13_1) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/16.1 Safari/605.1.15

Доменное имя ресурса

195.239.174.87

Правило анализа

Класс

web-application-attack

Группа

exploit

Название

AM EXPLOIT WordPress wpDiscuz 7.0.4 RCE and Shell Upload (CVE-2020-24186)

Описание:

Правило обнаруживает в сетевом трафике программный код, предназначенный для эксплуатации уязвимости

Текст:

```

alert top any any -> $HOME_NET $HTTP_PORTS (msg "AM EXPLOIT WordPress w
wpDiscuz 7.0.4 RCE and Shell Upload (CVE-2020-24186)":flow: established, to_serve
r,content: "2f?admin-ajax.php"/http_uri,content: "0d 0a/wmuUploadFiles"/http_clien
t_body/flowbits: isset,AM.Generic.php_injection/reference: cve.2020-24186,referen
ce: url.packetstormsecurity.com/files/162983/reference: url.packetstormsecurity.c
om/files/163012;classtype: web-application-attack,sid: 3153066;rev: 5;metadata:
affected_asset dst,affected_product gvecors:wpdiscuz,affected_product php:ph
p,affected_product wordpress:wordpress,affected_vendor gvecors,affected_van
dor php,affected_vendor wordpress,attack_target Web_Server, tag T1190, tias_ca
tegory Exploitation)

```

Описание уязвимостей

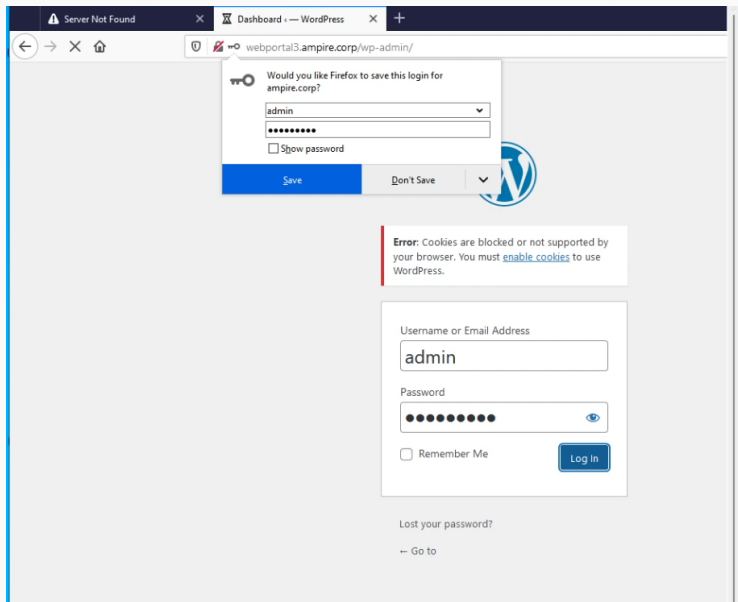
cve: 2020-24186

url: packetstormsecurity.com/files/162983

url: packetstormsecurity.com/files/163012

Рис. 1: ViPNet IDS NS

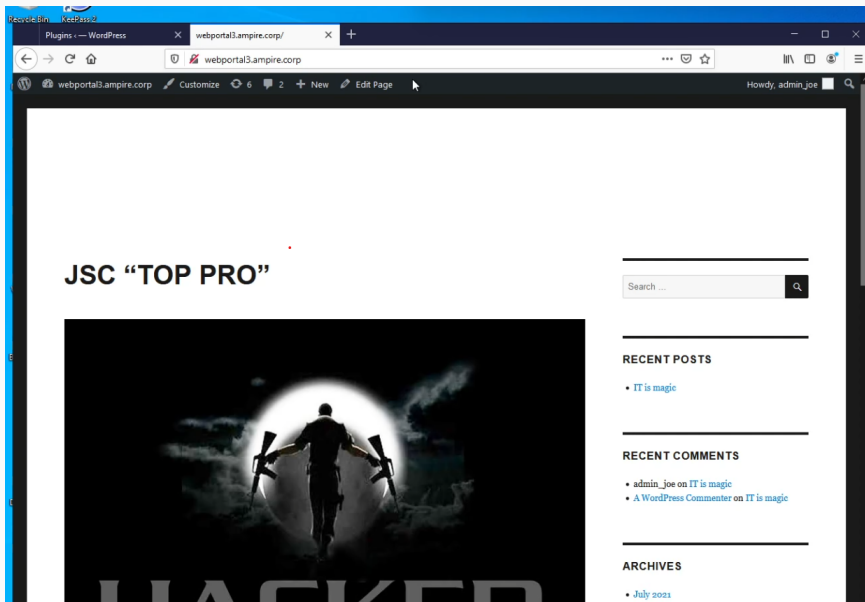
Вход в панель администратора



Отключение плагина в панели управления в WordPress

The screenshot shows the WordPress admin interface for the 'Plugins' section. The left sidebar contains navigation links: Dashboard, Activity Log, Posts, Media, Pages, Comments (2), wpDiscuz, Elementor, Templates, Essential Addons, Appearance, and Plugins (highlighted). Below the sidebar, there are links for 'Installed Plugins', 'Add New', 'Plugin Editor', 'Users', 'Tools', 'Settings', 'Duplicator', and 'Collapse menu'. The main content area displays a list of installed plugins. The 'UpdraftPlus - Backup/Restore' plugin is selected, and its 'Deactivate' link is being clicked. The plugin details show it is Version 1.16.65 by UpdraftPlus.Com, DavidAnderson. At the bottom, there is a 'Bulk actions' dropdown menu and an 'Apply' button.

Plugin	Version	Author	Actions
UpdraftPlus - Backup/Restore	Version 1.16.65	By UpdraftPlus.Com, DavidAnderson	Deactivate
WP File Manager	Version 7.1.2	By mndpsingh287	Deactivate
WP REST API Controller	Version 2.0.7	By YIKES, Inc.	Deactivate
wpDiscuz	Version 7.0.2	By gVectors Team	Deactivate



Существующие резервные копии UpdraftPlus

UpdraftPlus Backup/Restore



WP-Optimize

After you've backed up your database, we recommend you install our WP-Optimize plugin to streamline it for better website performance. [Read more](#)

[UpdraftPlus.Com](#) | [Premium](#) | [News](#) | [Twitter](#) | [Support](#) | [Newsletter sign-up](#) | [Lead developer's homepage](#) | [FAQs](#) | [More plugins](#) - Version: 1.16.65

Backup / Restore

Migrate / Clone

Settings

Advanced Tools

Premium / Extensions

Warning: WordPress has a number (27) of scheduled tasks which are overdue. Unless this is a development site, this probably means that the scheduler in your WordPress install is not working. [Read this](#)

Next scheduled backups:

Files:

Nothing currently scheduled

Time now: Sat, December 13, 2025 17:41

Database:

Nothing currently scheduled

Last log message:

The backup apparently succeeded and is now complete (Sep 15 08:49:23)

Existing backups 3

More tasks: [Upload backup files](#) | [Rescan local folder for new backup sets](#) | [Rescan remote storage](#)

☐	Backup date	Backup data (click to download)
☐	<u>Sep 15, 2023 8:49</u>	Database Plugins Themes Uploads Others
☐	Jul 27, 2023 9:26 📁	Database Plugins Themes Uploads Others
☐	Nov 30, 2021 9:37 📁	Database Plugins Themes Uploads Others

UpdraftPlus Restoration - Backup Sep 15, 2023 8:49

The restore operation has begun (e3e83a149409). Do not close this page until it reports itself as having finished.

✓ Restore successful!

[Return to UpdraftPlus configuration](#)

[Follow this link to download the log file for this restoration \(needed for any support requests\).](#)

Activity log

```
Moving old data out of the way...  
Moving unpacked backup into place...  
Cleaning up rubbish...
```

Uploads

```
Unpacking backup...  
(backup_2023-09-15-0849_webportal3ampirecorp_00140c92e515-  
uploads.zip, 2.5 MB)  
Unzip progress: 100 out of 100 files (2.5 MB,  
uploads/2021/11/sitesecure-1-300x225.jpeg)  
Moving old data out of the way...  
Moving unpacked backup into place...  
Cleaning up rubbish...
```

Restore successful!

Actions: [Return to UpdraftPlus configuration](#)

Отображение информации о TCP-соединениях

```
root@web-portal-3: ~  
user@web-portal-3:~$  
user@web-portal-3:~$  
user@web-portal-3:~$  
user@web-portal-3:~$ root  
  
Command 'root' not found, but can be installed with:  
  
sudo snap install root-framework  
  
user@web-portal-3:~$ sudo  
usage: sudo -h | -K | -k | -V  
usage: sudo -v [-AknS] [-g group] [-h host] [-p prompt] [-u user]  
usage: sudo -l [-AknS] [-g group] [-h host] [-p prompt] [-U user] [-u user]  
[command]  
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p  
prompt] [-T timeout] [-u user] [VAR=value] [-i|-s] [<command>]  
usage: sudo -e [-AknS] [-r role] [-t type] [-C num] [-g group] [-h host] [-p  
prompt] [-T timeout] [-u user] file ...  
user@web-portal-3:~$ sudo -i  
[sudo] password for user:  
root@web-portal-3:~# sudo ss =tnp  
Error: an inet prefix is expected rather than "=tnp".  
Cannot parse dst/src address.  
root@web-portal-3:~# sudo ss -tnp  
State      Recv-Q    Send-Q      Local Address:Port      Peer Address:Port  
CLOSE-WAIT 1          0          10.10.1.22:46314        195.239.174.11:5557  
  users: (("chisel.sh",pid=3330,fd=12), ("sh",pid=3329,fd=12), ("BKenU",pid=3307,fd=12))  
ESTAB      0          0          10.10.1.22:59084        195.239.174.11:5556  
  users: (("chisel.sh",pid=3330,fd=3), ("sh",pid=3329,fd=3), ("BKenU",pid=3307,fd=3))  
SYN-SENT   0          1          10.10.1.22:47220        195.239.174.125:8140  
  users: (("puppet",pid=25653,fd=6))  
ESTAB      0          64          10.10.1.22:22           10.10.1.253:32137  
  users: (("sshd",pid=25884,fd=3), ("sshd",pid=25746,fd=3))  
ESTAB      0          0          10.10.1.22:55860        195.239.174.11:1085  
  users: (("chisel.sh",pid=3330,fd=11))  
FIN-WAIT-2 0          0          10.10.1.22:41750        10.10.2.11:443  
  users: (("chisel.sh",pid=3330,fd=16))  
root@web-portal-3:~#
```

Процесс закрытия meterpreter-сессии

```
State          Recv-Q      Send-Q      Local Address:Port      Peer Address:Port
ESTAB          0           0           10.10.1.22:22           10.10.1.253:17105
users: (("sshd",pid=5323,fd=3), ("sshd",pid=5255,fd=3))
FIN-WAIT-2     0           0           10.10.1.22:38580       10.10.2.11:443
users: (("chisel.sh",pid=1863,fd=16))
ESTAB          0           0           10.10.1.22:59624       195.239.174.11:5556
users: (("chisel.sh",pid=1863,fd=3), ("sh",pid=1862,fd=3), ("jIwcT",pid=1841,fd=3))
ESTAB          0           0           10.10.1.22:51944       195.239.174.11:1085
users: (("chisel.sh",pid=1863,fd=11))
ESTAB          0           64          10.10.1.22:22           10.10.1.253:64405
users: (("sshd",pid=5028,fd=3), ("sshd",pid=4887,fd=3))
CLOSE-WAIT     0           0           10.10.1.22:60796       195.239.174.11:5557
users: (("chisel.sh",pid=1863,fd=12), ("sh",pid=1862,fd=12), ("jIwcT",pid=1841,fd=12))
root@web-portal-3:~# kill 1863
root@web-portal-3:~# sudo ss -tnp
State          Recv-Q      Send-Q      Local Address:Port      Peer Address:Port
FIN-WAIT-2     0           0           10.10.1.22:38580       10.10.2.11:443
ESTAB          0           0           10.10.1.22:59624       195.239.174.11:5556
users: (("jIwcT",pid=1841,fd=3))
ESTAB          0           64          10.10.1.22:22           10.10.1.253:64405
users: (("sshd",pid=5028,fd=3), ("sshd",pid=4887,fd=3))
CLOSE-WAIT     0           0           10.10.1.22:60796       195.239.174.11:5557
```

IP Address and Domain Restrictions.

The screenshot displays the Internet Information Services (IIS) Manager interface. The breadcrumb navigation at the top shows the path: MAIL > Sites > Default Web Site > ecp. The left-hand tree view shows the hierarchy: Start Page > MAIL (AMPIRE\administrator) > Application Pools > Sites > Default Web Site > ecp. The main content area is titled "IP Address and Domain Restrictions" and includes a description: "Use this feature to restrict or grant access to Web content based on IP addresses or domain names. Set the restrictions in order of priority." Below this, a dialog box titled "Edit IP and Domain Restrictions Settings" is open. It features a dropdown menu for "Access for unspecified clients" with "Deny" selected. There is an unchecked checkbox for "Enable Proxy Mode" and a "Deny Action Type" dropdown set to "Not Found". The "Actions" pane on the right lists several options, with "Edit Feature Settings..." highlighted. A red arrow points from the "Edit Feature Settings..." link to the "Deny" option in the dropdown menu.

Internet Information Services (IIS) Manager

MAIL > Sites > Default Web Site > ecp

File View Help

Connections

- Start Page
- MAIL (AMPIRE\administrator)
 - Application Pools
 - Sites
 - Default Web Site
 - API
 - aspnet_client
 - Autodiscover
 - ecp
 - auth
 - EWS
 - mapi
 - Microsoft-Server-A
 - OAB
 - owa
 - PowerShell
 - Rpc
 - Exchange Back End

IP Address and Domain Restrictions

Use this feature to restrict or grant access to Web content based on IP addresses or domain names. Set the restrictions in order of priority.

Edit IP and Domain Restrictions Settings

Access for unspecified clients:

Deny

Allow

Deny

☐ Enable Proxy Mode

Deny Action Type:

Not Found

OK Cancel

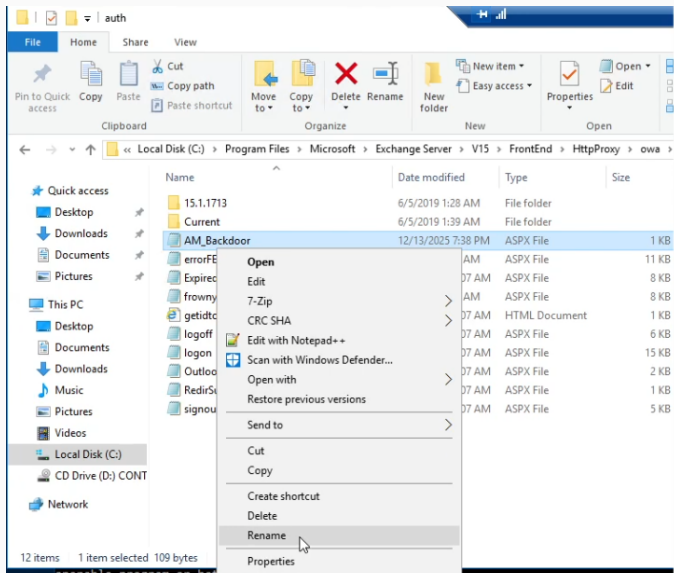
Actions

- Add Allow Entry...
- Add Deny Entry...
- Edit Feature Settings...
- Revert to Parent
- View Ordered List...
- View Dynamic Restriction Settings...
- Help

```
[msexchangepl.exe]  
C:\Users\administrator.AMPIRE>taskkill /PID 2108 /F  
SUCCESS: The process with PID 2108 has been terminated.  
C:\Users\administrator.AMPIRE>taskkill /PID 2108_ /F
```

Рис. 10: Завершение процессов.

Удаление файла AM BACKDOOR.





admin@rocket-local.com

Reset password

[Back to login](#)

By proceeding you are agreeing to our [Terms of Service](#), [Privacy Policy](#) and [Legal Notice](#).

Powered by [Open Source Chat Platform Rocket.Chat](#).

Ссылка для сброса пароля

```
Subject: Rocket.Chat - Password Recovery
Message-ID: <d8e0c330-3414-264a-a8ff-c714238b36e3@rocket-local.com>
Date: Sat, 13 Dec 2025 17:22:00 +0000
MIME-Version: 1.0

----- NmP-aded3d9d2d4c5f9c-Part_1
Content-Type: text/plain
Content-Transfer-Encoding: quoted-printable

Hello,

To reset your password, simply click the link below.

http://10.10.2.22:3000/reset-password/5DCpmrNVefkDd2buG1l7a7NpG_Rogrdz5TEZK=
tae3N3

Thanks.

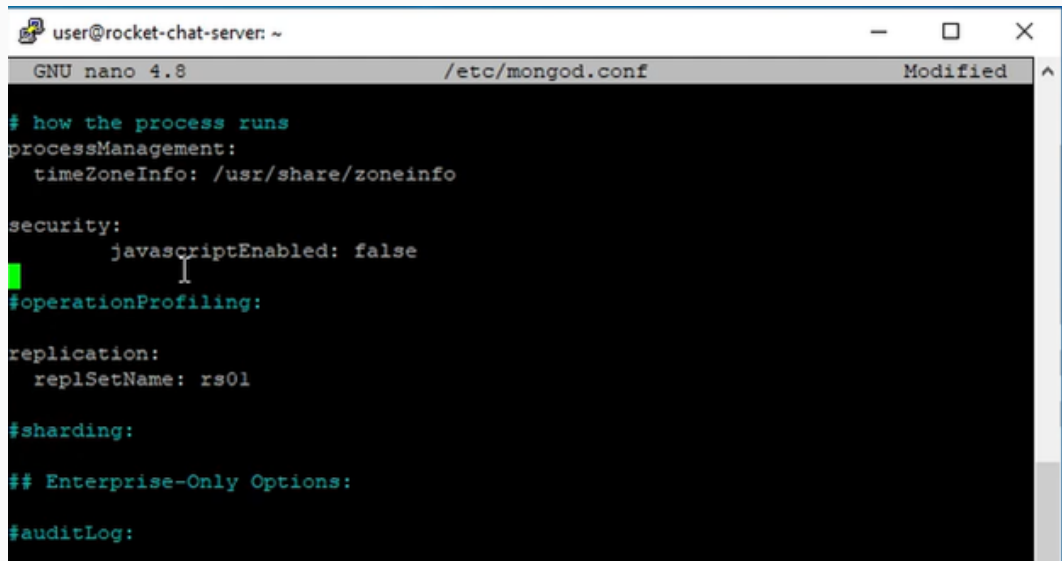
----- NmP-aded3d9d2d4c5f9c-Part_1
Content-Type: text/html; charset=utf-8
Content-Transfer-Encoding: quoted-printable

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd"><html xmlns=3D"http://www.w3.org/1999/xhtml" style=3D"font-family: -apple-system,BlinkMacSystemFont, 'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif;"><head><!-- If you delete this tag, the sky will fall on your head --><meta name=3D"viewport" content=3D"width=3Ddevice-width"><meta http-equiv=3D"Content-Type" content=3D"text/html; charset=3DUTF-8"><title>Rocket.Chat Cloud</title></head><body bgcolor=3D"#F7F8FA" style=3D"font-family: -apple-system,BlinkMacSystemFont, 'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif; width: 100%; height: 100%;"><table class=3D"body" bgcolor=3D"#F7F8FA" width=3D"100%" style=3D"font-family: -apple-system,BlinkMacSystemFont, 'Segoe UI',Roboto,Oxygen,Ubuntu,Cantarell,'Helvetica Neue','Apple Color Emoji','Segoe UI Emoji','Segoe UI Symbol','Meiryo UI',Arial,sans-serif; width: 100%; height: 100%;"><tr><td><!-- HEADER --><table class=3D"wrap" bgcolor=3D"#F7F8FA" style=3D"width: 100%; clear: both;"><tr><td class=3D"header container" style=3D"display: block; max-width: 640px; margin: 0 auto; clear: both; border-radius: 2px;"><div class=3D"header-content" style=3D"list-style-position: inside; padding: 16px 0; padding-top: 36px; padding-bottom: 36px; padding-left: 36px; padding-right: 36px; max-width: 640px; margin: 0 auto; display: block;"><table bgcolor=3D"#F7F8FA" width=3D"100%"><tr><td><img src=3D"http://10.10.2.22:3000/assets/logo.png" alt=3D"Rocket.chat" =
```

back_up коды для двух. аутентификации

```
user@rocket-chat-server: ~  
  
You have mail.  
Last login: Sat Dec 13 17:40:26 2025 from 10.10.2.2  
admin@rocket-chat-server:~$ su -user  
Try 'su --help' for more information.  
admin@rocket-chat-server:~$ su - user  
Password:  
user@rocket-chat-server:~$ cd /home  
user@rocket-chat-server:/home$ cat DROP_DB_INFO  
cat: DROP_DB_INFO: No such file or directory  
user@rocket-chat-server:/home$ cd ..  
user@rocket-chat-server:/$ cat backup_codes  
cat: backup_codes: No such file or directory  
user@rocket-chat-server:/$ cat backup_codes  
cat: backup_codes: No such file or directory  
user@rocket-chat-server:/$ cd /home/user/  
user@rocket-chat-server:~$ ls  
backup_codes  
user@rocket-chat-server:~$ cat backup_codes  
backup codes for admin Rocket Chat:  
iFdDR68y kpMifh9E 43PxEyom jho4DGdw RiuwYGrG LohP2b  
rdhcBy8B DvPHRnTz ZZPgeko2  
user@rocket-chat-server:~$
```

Настройка конфигурации БД



The screenshot shows a terminal window with the title bar "user@rocket-chat-server: ~". The terminal is running the GNU nano 4.8 text editor, editing the file /etc/mongod.conf. The editor's status bar at the top indicates "Modified". The configuration file content is as follows:

```
# how the process runs
processManagement:
  timeZoneInfo: /usr/share/zoneinfo

security:
  javascriptEnabled: false

#operationProfiling:

replication:
  replSetName: rs01

#sharding:

## Enterprise-Only Options:

#auditLog:
```

A cursor is visible on the line "javascriptEnabled: false".

```
root@rocket-chat-server:~# sudo ss -tnp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address:Port
Process
ESTAB      0            0            10.10.2.22:22            10.10.2.254:55491
  users: (("sshd",pid=17301,fd=4), ("sshd",pid=17211,fd=4))
ESTAB      0            64            10.10.2.22:22            10.10.2.254:61308
  users: (("sshd",pid=12791,fd=4), ("sshd",pid=12715,fd=4))
ESTAB      0            0            10.10.2.22:47990         195.239.174.11:5559
  users: (("testsystem",pid=3443,fd=3))
root@rocket-chat-server:~# kill 3443
root@rocket-chat-server:~# sudo ss -tnp
State      Recv-Q      Send-Q      Local Address:Port      Peer Address:Port
Process
ESTAB      0            0            10.10.2.22:22            10.10.2.254:55491
  users: (("sshd",pid=17301,fd=4), ("sshd",pid=17211,fd=4))
ESTAB      0            64            10.10.2.22:22            10.10.2.254:61308
  users: (("sshd",pid=12791,fd=4), ("sshd",pid=12715,fd=4))
root@rocket-chat-server:~# curl -fsSL https://deb.nodesource.com/setup_14.x | sudo -E bash -;
curl: (6) Could not resolve host: deb.nodesource.com
root@rocket-chat-server:~#
```

Рис. 16: Удаление соединений

Вывод

В ходе выполнения лабораторной работы были изучены и практически освоены методы обнаружения, анализа и устранения сложных многоэтапных кибератак на корпоративную инфраструктуру с использованием учебно-тренировочного комплекса Empire.

Были исследованы три критические уязвимости в различных компонентах инфраструктуры: WpDiscuz, Rocket.Chat, Proxylogon.

Список литературы. Библиография
